FAQ: Aadhaar Sandbox Auth Integration

What does error code 502 mean?

Error code 502 indicates "Invalid encryption of PID" (Personal Identity Data). This error occurs when the PID block in the authentication XML request is not properly encrypted. To resolve this:

- Verify that the PID encryption is using the correct session key
- Ensure the encryption algorithm matches UIDAI specifications
- Check that the certificate identifier (ci attribute) in the Skey element is valid
- Details of Authentication error codes can be found https://uidai.gov.in/en/305-faqs/aadhaar-online-services/aadhaar-authentication-history/10779-what-are-error-codes.html

What does error code 503 mean?

Error code 503 indicates "Invalid encryption of Hmac". This error suggests that the HMAC (Hash-based Message Authentication Code) encryption in your request is incorrect. Resolution steps include:

- Validate the HMAC generation process
- Ensure the session key used for HMAC encryption is properly synchronized
- Verify the timestamp (ts) is prepended to the request as required
- Details of Authentication error codes can be found https://uidai.gov.in/en/305-faqs/aadhaar-online-services/aadhaar-authentication-history/10779-what-are-error-codes.html

What does error code 541 mean?

Error code 541 indicates "Invalid PID XML version". This occurs when the PID (Personal Identity Data) block version specified in your authentication request doesn't match the expected version. To fix this:

- Ensure you're using PID version 2.5 as specified in the Auth element
- Verify the "ver" attribute in the Pid element matches the supported version
- Check that your XML structure follows the correct format for API version 2.5

- Details of Authentication error codes can be found https://uidai.gov.in/en/305-faqs/aadhaar-online-services/aadhaar-authentication-history/10779-what-are-error-codes.html

What does error code 940 mean?

Error code 940 indicates "Unauthorized ASA channel". This error means the Authentication Service Agency (ASA) channel being used is not authorized. Resolution steps:

- Verify that your ASA credentials are correctly configured
- Confirm that the ASA has been properly onboarded with UIDAI
- Check if server restart is needed (as mentioned in the chat history, this resolved the issue)
- Ensure the ASA code in your request matches the registered ASA
- Details of Authentication error codes can be found https://uidai.gov.in/en/305-faqs/aadhaar-online-services/aadhaar-authentication-history/10779-what-are-error-codes.html

What is the correct XML format for authentication requests?

The authentication request must follow this structure:

- Root element: `<Auth>` with required attributes (uid, rc, tid, ac, sa, ver, txn, lk)
- `<Uses>` element specifying authentication factors (pi, pa, pfa, bio, bt, pin, otp)
- `<Device>` element with device metadata
- `<Skey>` element with certificate identifier (ci) containing the encrypted session key
- Optional `<Data>` element for encrypted PID
- Timestamp (ts) should be prepended to specific elements as per UIDAI requirements

Why is the timestamp (ts) important in the request?

The timestamp must be prepended to the authentication request as discussed in the integration. The timestamp format should be: `YYYY-MM-DDTHH:MM:SS.mmm+05:30` (IST time zone). This ensures request freshness and prevents replay attacks

How do I successfully implement Send OTP and Verify OTP APIs?

Successful implementation requires:

- For Send OTP: Submit a valid OTP request with correct ASA credentials and Sandbox UID/VID
- Store the transaction ID (txn) received in the OTP response
- For Verify OTP: Use the same transaction ID (txn) from the Send OTP request in your verification request
- Ensure the txn values match exactly between both API calls to prevent interception

What should I do if OTP requests fail intermittently?

Based on the chat history, error 940 during OTP requests can often be resolved by restarting the authentication servers. If errors persist, verify ASA channel authorization and check server connectivity.

.

What should I do when authentication suddenly stops working?

Based on the chat history:

- First, check if the issue is a known error code (502, 503, 541, 940)
- Try restarting authentication servers on your end
- Verify that your ASA credentials and channels are still valid
- Contact UIDAI authentication support team if the issue persists
- Check if there are any ongoing maintenance activities on UIDAI servers

Who should I contact for integration support?

The integration involves coordination between AUA technical team, UIDAI technical team, and Aadhaar authentication support. Maintain communication channels with all stakeholders during the integration process for quick resolution of issues.

What encryption standards must be used for Aadhaar authentication?

Aadhaar authentication requires strict encryption standards:

- Session Key: AES-256 session key must be dynamically generated for every transaction
- Public Key Encryption: The AES-256 session key must be encrypted using UIDAI's 2048-bit RSA public key
- PID Block Encryption: Personal Identity Data must be encrypted using the AES-256 session key
- HMAC: SHA-256 hash of the PID block must be computed, then encrypted using the session key

How should session keys be managed securely?

Session key management is critical for security:

- Generate a new AES-256 session key dynamically for every authentication transaction
- Never reuse session keys across multiple transactions
- Do not store session keys anywhere except in memory during the transaction
- Session keys must be destroyed immediately after the transaction completes
- If using Hardware Security Modules (HSMs), ensure proper key lifecycle controls

What is the correct process for encrypting the PID block?

The PID block encryption follows a specific sequence:

1. From the PID XML containing resident's identity data
2. Encrypt the PID XML using the AES-256 session key
3. Encode the encrypted data using base-64 encoding
4. The encoded value goes into the `<Data>` element of the authentication request

How should HMAC be calculated and encrypted?

HMAC calculation and encryption follows these steps:

1. Form the complete PID XML string
2. Compute SHA-256 hash of the PID XML string
3. Encrypt the hash using the same AES-256 session key used for PID encryption
4. Encode the encrypted hash using base-64 encoding

5. Place the encoded value in the `<Hmac>` element

What is the Skey element and how should it be formatted?

The Skey element contains the encrypted session key:

- Generate a 256-bit AES session key
- Encrypt it using UIDAI's 2048-bit RSA public key certificate
- Base-64 encode the encrypted session key
- Place it in the `<Skey>` element with the mandatory "ci" attribute
- The "ci" attribute must contain the certificate expiration date in YYYYMMDD format (e.g., "20300811")

What is the certificate identifier (ci) and why is it important?

The certificate identifier (ci) is mandatory in the Skey element:

- It specifies which UIDAI public key certificate was used to encrypt the session key
- UIDAI may have multiple public keys in use simultaneously
- Format: YYYYMMDD representing the certificate expiration date
- Must NOT be hard-coded; should be configurable in your application
- Using an incorrect or expired ci value will result in error code 501

What are the mandatory security requirements for PID data?

UIDAI mandates strict security controls for PID handling:

- PID block must be encrypted during capture and never sent in clear text over networks
- Encrypted PID blocks should not be stored except for buffered authentication for short periods
- Biometric and OTP data must never be stored in permanent storage or databases
- All authentication data must be encrypted in transit using secure protocols
- Encryption at rest must use AES-256 or equivalent standards

Where can I obtain UIDAI public key certificates?

UIDAI public key certificates are available from the official UIDAI developer portal. These certificates are required to:

- Encrypt the AES-256 session key
- Validate the certificate identifier (ci) attribute
- Ensure compatibility with current UIDAI authentication infrastructure

What happens if I reuse session keys?

Reusing session keys is strictly prohibited and poses serious security risks:

- Each transaction must use a freshly generated AES-256 session key
- Reusing keys can lead to authentication failures
- It violates UIDAI security guidelines and may result in audit non-compliance
- Session key reuse can be exploited for replay attacks

How should authentication data be stored?

Authentication data storage must follow strict guidelines:

- Biometric data must never be stored
- OTP data must never be stored in any permanent storage
- Authentication logs should be encrypted using AES-256 at rest
- Encrypted PID blocks can only be temporarily stored for buffered authentication
- All logs containing sensitive data must be protected with access controls

Where can I find the CI?

- The CI Value is here CI=20300811
- For updated or revised CI details, please reach out to the UIDAI Auth Support Team

Where can I find the Public Certificate?

- Navigate to the UIDAI Developer Section on official UIDAI website
- Navigate to Data and Download and UIDAI Certificates
- Use the provided Link to access :
- https://uidai.gov.in/en/ecosystem/authentication-devices-documents/developer-section/916-developer-section/data-and-downloads-section.html

Where can I find the AUA/ASA license and AUA/Sub-AUA keys?

- Visit the official UIDAI website and navigate to Developer section
- Go to the Testing Data and License Keys
- https://uidai.gov.in/en/ecosystem/authentication-devices-documents/developer-section/916-developer-section/data-and-downloads-section.html
- Find the Test codes